

Enterprise Data Processing & Financial Services Agreement

FinServ Corp Ltd. | Contract Ref: FSC-2026-0042 | June 2026

SECTION 1: DATA COLLECTION AND LAWFUL BASIS

The Company processes personal data under Article 6 of GDPR on the basis of contractual necessity and legitimate interests. All data subjects are informed of the legal basis at the point of collection via our privacy notice published at www.finservcorp.com/privacy. Consent records are maintained in our CRM system with timestamps.

SECTION 2: DATA RETENTION POLICY

Customer personal data is retained indefinitely for internal analytics and business intelligence purposes. No formal data deletion schedule has been established. Personal data including transaction history and contact details is shared with third-party advertising partners for targeted marketing without explicit customer consent.

SECTION 3: DATA BREACH NOTIFICATION

In the event of a personal data breach, the Company will notify the relevant supervisory authority within 72 hours of becoming aware of the breach, in accordance with GDPR Article 33. Affected individuals will be notified without undue delay where the breach poses a high risk to their rights and freedoms. A documented incident response plan is maintained by the Information Security team.

SECTION 4: INTERNAL FINANCIAL CONTROLS

The Company does not currently maintain formally documented internal controls over financial reporting (ICFR). No independent external auditor review of internal controls has been conducted for the current fiscal year. Financial control assessments are performed informally on a quarterly basis by the CFO office without formal documentation.

SECTION 5: FINANCIAL RECORD RETENTION

All financial records, audit workpapers, transaction logs, and supporting documentation are retained for a minimum period of 7 years in accordance with SOX Section 802 requirements. Records are stored in encrypted, access-controlled cloud repositories with full audit trails. Destruction of records before the retention period requires CFO sign-off.

SECTION 6: WHISTLEBLOWER POLICY

Employees are encouraged to report compliance concerns directly to their line manager. No formal anonymous

SECTION 7: AML AND KYC COMPLIANCE

For high-value transactions exceeding \$10,000, enhanced due diligence is performed manually by the compliance team. Standard account creation requires only email verification. No formal automated AML screening process is documented or consistently applied across all customer segments.

SECTION 8: CAPITAL ADEQUACY

The Company maintains capital reserves as per regulatory minimums. Quarterly solvency assessments are conducted by the Finance team and reviewed by the Board Risk Committee. Capital adequacy ratios are calculated using the standard formula and reported in the annual regulatory filing.

SECTION 9: CLAIMS PROCESSING TIMELINE

Insurance claims are acknowledged in writing within 10 business days of receipt. Target resolution is set at 45 business days, which exceeds the 30-day regulatory requirement. A digital claims tracking system is in place. SLA breaches are reported to the COO monthly.

SECTION 10: THIRD PARTY DATA PROCESSORS

Customer data is shared with 8 external service providers including cloud storage, analytics, and marketing platforms. GDPR-compliant Data Processing Agreements have been established with 5 of the 8 vendors. Agreements with the remaining 3 vendors are currently under legal review and expected to be executed within 60 days.

SECTION 11: PROTECTED HEALTH INFORMATION

The Company handles limited Protected Health Information (PHI) for employee benefits and occupational health administration. Access to PHI is restricted to authorised HR and medical personnel only. Business Associate Agreements have not yet been executed with our 3 benefits administration vendors. Audit logging for PHI system access has not been implemented.

SECTION 12: PAYMENT CARD DATA SECURITY

Customer payment transactions are processed exclusively via a PCI-DSS Level 1 certified third-party payment gateway. The Company does not store, process, or transmit raw Primary Account Numbers (PAN). Network segmentation between the payment processing environment and internal corporate systems is enforced via firewall rules, reviewed on a quarterly basis by the IT Security team.